Аналіз безпекових
вимог для СУМЗ

Домашнє завдання 3 • SQUARE Essentials

Виконав: Задорожняк Ігор
Проєкт: MedRecordsManager

1. Мета та межі аналізу

Мета роботи - перетворити загрози, визначені в попередньому STRIDE-аналізі, на конкретні та перевіряльні вимоги до безпеки. Використано навчальний підхід SQUARE Essentials: актив → сценарій загрози → вимога → критерій прийняття. Це скорочене застосування підходу, а не повний дев'ятиетапний процес SQUARE [1].

MedRecordsManager - система управління медичними записами приватної клініки. Вебінтерфейс і мобільний застосунок звертаються до API; API перевіряє автентифікацію та дозволи й працює з базою даних. Сервіс експорту через чергу отримує завдання та створює PDF у приватному сховищі. Окремо працюють журнал аудиту, резервне копіювання та e-mail-доставка посилань.

Ролі та правила доступу

Роль	Дозволені дії
Пацієнт	Перегляд та експорт лише власних медичних записів; зміна дозволених полів власного профілю.
Лікар	Перегляд і зміна записів лише за наявності чинного серверного зв'язку з пацієнтом та дозволу на відповідну дію.
Адміністратор	Керування користувачами й налаштуваннями. Адміністративна роль сама по собі не надає доступу до змісту медичних записів.

Цілі безпеки

Конфіденційність: не допустити розкриття медичних даних стороннім. Цілісність: дозволяти лише авторизовані та простежувані зміни. Доступність: забезпечити відновлення записів і роботи системи після інциденту.

Числові параметри нижче - запропоновані критерії цієї навчальної моделі, які мають бути погоджені з клінікою перед впровадженням. Вони не є законодавчими строками чи підтвердженими характеристиками наявної системи.

2. Ключові активи

C - конфіденційність; I - цілісність; A - доступність. У кожній клітинці наведено рівень впливу та можливу шкоду. В - високий, С - середній, Н - низький. Загальна критичність визначається найтяжчим наслідком для пацієнтів або роботи клініки.

Актив / тип	**Критичність**	**C: розкриття**	**I: зміна**	**A: втрата доступу**
A1. Медичні записи Інформаційний	Висока	В: витік діагнозів, аналізів та історій хвороб.	В: хибні дані про алергії чи лікування впливають на рішення лікаря.	В: затримка консультацій і лікування.
A2. Облікові дані та сеанси Логічний	Висока	В: викрадений пароль або токен дає змогу діяти від імені користувача.	В: підроблена сесія дозволяє обійти ідентифікацію.	С: користувачі не можуть увійти до відновлення доступу.
A3. Ролі, дозволи та зв’язки лікар–пацієнт Логічний	Висока	С: розкриття структури доступу полегшує цільову атаку.	В: зміна ролі або зв’язку відкриває чужі записи.	В: неможливо безпечно дозволити доступ до записів.
A4. Журнал аудиту Інформаційний	Висока	С: витік метаданих про користувачів та факти звернення до записів.	В: підроблення приховує автора і зміст операції.	С: затримка розслідування та виявлення інциденту.
A5. PDF-експорти Інформаційний	Висока	В: стороння особа отримує копію медичних даних.	В: підміна висновку вводить одержувача в оману.	С: затримка видачі документа; оригінал може лишатися доступним.
A6. Резервні копії БД Інформаційний	Висока	В: масовий витік даних пацієнтів із копії.	В: пошкоджена копія відновлює недостовірні записи.	В: після втрати основної БД неможливо відновити роботу.

Обґрунтування вибору

Активи охоплюють первинні дані, їхні похідні та резервні копії, механізми контролю доступу й докази виконаних дій. Усі мають високу загальну критичність через хоча б один тяжкий наслідок, проте рівні C / I / A відрізняються. API та БД розглядаються як компоненти, що обробляють ці активи, а не як додаткові рядки таблиці.

3. Сценарії загроз

Сценарії розвивають результати ДЗ2. Позначення STRIDE тут означають: S - підміна особи, T - несанкціонована зміна, R - заперечення дій, I - розголошення, D - відмова в обслуговуванні, E - підвищення привілеїв. Літера I у STRIDE не тотожна цілісності I у тріаді C / I / A.

T1. Доступ до чужого запису через ID

A1, A3 • STRIDE: I

Автентифікований пацієнт змінює ID у GET /records/{id}. API перевіряє лише факт входу, тому повертає історію хвороби іншого пацієнта. Наслідок - порушення конфіденційності. Це сценарій BOLA [2].

T2. Несанкціонована зміна медичних полів

A1, A3 • STRIDE: T, E

Пацієнт додає diagnosis або doctor_id до запиту зміни профілю. Сервер без перевірки дозволених полів записує їх у БД. Наслідок - підроблений діагноз або незаконна зміна зв’язку лікаря з пацієнтом.

T3. Захоплення облікового запису лікаря

A2, A1, A5 • STRIDE: S

Зловмисник отримує пароль лікаря через фішинг або викрадає активний токен. За відсутності другого фактора чи своєчасного відкликання сеансу він переглядає, змінює або експортує записи в межах прав лікаря.

T4. Приховування виконаної зміни

A4, A1 • STRIDE: R, T

Працівник змінює запис, а потім через надмірні права видаляє подію аудиту; або журнал містить лише IP без ID користувача. Він заперечує дію, а клініка не може надійно встановити її автора.

T5. Витік PDF через переслане посилання

A5, A1, A3 • STRIDE: I

Одержувач пересилає посилання сторонній особі. Сховище або endpoint завантаження не перевіряє користувача та актуальні права, тому стороння особа отримує PDF навіть після відкликання доступу ініціатора.

T6. Видалення основної БД і резервних копій

A6, A1 • STRIDE: D, T

Атакувальник захоплює привілейований акаунт БД і видаляє записи та копії, доступні з тими самими обліковими даними. Клініка втрачає історії хвороб і не може відновити обслуговування.

4. Перевіряльні вимоги

SR-01–SR-06 мають пріоритет Must: необхідні до використання реальних медичних даних. Перевірки нижче є критеріями прийняття, а не звітом про вже виконане тестування. Для тестів використовуються вигадані дані.

SR-01. Авторизація кожного медичного запису

Активи: A1, A3 • Загроза: T1 • Виконавець: backend

Вимога. API повинно на кожному запиті читання, пошуку, зміни й експорту перевіряти роль, дозволену операцію та право на конкретний запис. Пацієнту доступні лише власні записи; лікарю - лише записи пацієнтів із чинним серверним зв'язком. За відсутності явного дозволу доступ забороняється. Адміністратор не отримує клінічний доступ лише завдяки ролі.

Перевірка. Для пацієнтів P1 і P2, лікаря зі зв'язком із P1 та адміністратора перевірити прямі запити, пошук і експорт. Власник і призначений лікар отримують дозволені дані; доступ P1 до P2, лікаря до P2 та адміністратора без клінічного дозволу дає 403 або 404 без медичних даних. Пошук не повертає чужих записів.

Обґрунтування. Блокує сценарій підміни ID; успішний вхід і знання ID самі по собі не надають права на медичну інформацію.

SR-02. Контроль полів і захист від перезапису

Активи: A1, A3 • Загроза: T2 • Виконавець: backend

Вимога. Сервер повинен використовувати дозволений перелік полів для кожної ролі та операції. Запит профілю пацієнта з diagnosis, doctor_id або role відхиляється повністю. Клінічні поля змінює лише уповноважений лікар через окрему операцію. Оновлення медичного запису повинно містити очікувану версію; застаріла версія не записується.

Перевірка. Надіслати заборонені поля від пацієнта: отримати 400 або 403, дані й дозволи незмінні. Дозволена зміна від лікаря успішна. Для двох запитів з однаковою початковою версією другий отримує 409, а результат першого зберігається.

Обґрунтування. Не дозволяє змінити діагноз або права через зайві поля та запобігає непомітній втраті паралельних клінічних змін.

SR-03. MFA та відкликання сеансів персоналу

Активи: A2, A1, A5 • Загроза: T3 • Виконавці: IAM / backend

Вимога. Вхід лікарів і адміністраторів повинен вимагати MFA. До завершення другого фактора медичне API недоступне. Access-токен діє не довше 15 хвилин; сервер перевіряє підпис, строк дії, видавця й адресата. Після блокування акаунта або відкликання сесії всі пов'язані access- і refresh-токени повинні втратити чинність не пізніше ніж за 60 секунд.

Перевірка. Самого правильного пароля недостатньо для доступу. Прострочений токен або токен з неправильним підписом, видавцем чи адресатом дає 401. Через 60 секунд після відкликання попередній access-токен і спроба оновлення сесії відхиляються.

Обґрунтування. MFA зменшує ризик входу з викраденим паролем; відкликання обмежує використання викраденого токена. Саме MFA не захищає вже викрадений сеанс.

4. Вимоги до аудиту, експорту й відновлення

SR-04. Окремий захищений аудит

Активи: A4, A1 • Загроза: T4 • Виконавці: backend / DevOps

Вимога. Система повинна фіксувати читання, зміни, експорт, зміни прав та відмови доступу: UTC-час, ID користувача, дію, ID об’єкта, результат і ID запиту; для зміни - попередню й нову версію. Події передаються в окреме сховище не пізніше 60 секунд. Ролі клініки та акаунти API не можуть змінювати чи видаляти прийняті події. Діагнози, паролі, токени й вміст PDF не записуються в журнал.

Перевірка. Виконати всі перелічені дії та перевірити наявність обов’язкових полів у журналі через 60 секунд. Спроби UPDATE/DELETE від акаунта API й адміністратора застосунку відхиляються. Пошук контрольного пароля, токена та діагнозу в журналі не дає збігів.

Обґрунтування. Забезпечує простежуваність і ускладнює приховування змін. Аудит допомагає розслідуванню, але сам не запобігає несанкціонованій дії.

SR-05. Контроль доступу протягом експорту

Активи: A5, A1, A3 • Загрози: T5, T1 • Виконавці: backend / DevOps

Вимога. Сервіс повинен повторно перевіряти права ініціатора перед генерацією PDF; завантаження потребує входу та актуального дозволу на всі включені записи. PDF зберігаються лише приватно. Посилання діє не довше 15 хвилин; тимчасовий PDF видаляється не пізніше 24 годин після створення. E-mail містить повідомлення з посиланням без медичних даних і вкладеного PDF.

Перевірка. Переслане посилання не видає PDF сторонньому чи анонімному користувачу. Після відкликання прав завдання в черзі та завантаження відхиляються. Перевірити недоступність прямого URL сховища, закінчення строку посилання, видалення PDF та вміст листа.

Обґрунтування. Запобігає отриманню документа лише завдяки знанню URL і враховує зміну дозволів. Уже завантажену копію система не може надійно відкликати.

SR-06. Ізольовані копії та перевірене відновлення

Активи: A6, A1 • Загроза: T6 • Виконавець: DevOps

Вимога. Резервне копіювання повинно забезпечувати RPO ≤ 24 годин і RTO ≤ 4 годин. Щонайменше одна придатна копія повинна мати захист від зміни й видалення на 30 діб та окремі облікові дані, недоступні акаунтам API й адміністратора основної БД. Повне тестове відновлення проводиться щокварталу.

Перевірка. У тестовому середовищі видалити основну БД і спробувати видалити захищену копію її адміністративним акаунтом: операція заборонена. Від оголошення інциденту до доступності API з відновленими записами має минути ≤ 4 годин; втрата даних - ≤ 24 годин. Звірити контрольні записи та зафіксувати протокол.

Обґрунтування. Знижує наслідки знищення БД. RPO визначає допустиму втрату даних у часі, RTO - час відновлення; сам факт створення копії не доводить її придатності.

Джерела

[1] Carnegie Mellon SEI. Security Quality Requirements Engineering Technical Report. https://www.sei.cmu.edu/library/security-quality-requirements-engineering-technical-report/

[2] OWASP. API1:2023 Broken Object Level Authorization. https://api-security.owasp.org/editions/2023/en/0xa1-broken-object-level-authorization/

Основа проєкту: Д32 «STRIDE аналіз СУМЗ», Задор Ігор, MedRecordsManager.